

GUÍA METODOLÓGICA EXHAUSTIVA DE ENCUESTA CRA-CYBER

Análisis, Cálculos y Procedimientos de Implementación

Versión: 2.1

Fecha: Enero 2026

Público Objetivo: Investigadores, Analistas de Ciberseguridad, Consultores, CISOs

TABLA DE CONTENIDOS

1. Fundamento Metodológico
2. Procedimiento de Administración
3. Análisis Descriptivo
4. Cálculos CAsPeA
5. Métricas de Madurez
6. Benchmarking
7. Análisis de ROI
8. Tratamiento de Datos Faltantes
9. Validación y Aseguramiento de Calidad

FUNDAMENTO METODOLÓGICO {#fundamento}

Diseño de Investigación

La encuesta CRA-Cyber utiliza **diseño observacional transversal** (cross-sectional) con elementos de cuasi-experimentalismo (comparación de grupos de control).

Población objetivo: Responsables de ciberseguridad, CISOs, directores de IT, auditores internos en organizaciones españolas de cualquier sector crítico (NIS2 aplicable) o tamaño (>50 empleados).

Tamaño de muestra recomendado:

- Mínimo por sector: 15-20 organizaciones ($n \geq 15$)
- Ideal por sector: 30-50 organizaciones ($n = 30-50$)
- Total nacional meta: 150-250 respondentes distribuidos entre 7-8 sectores

Margen de error esperado:

- Con $n=150$, $\sigma=0.5$ (máxima heterogeneidad), intervalo confianza 95%: margen $\pm 8\%$
- Con $n=250$, $\sigma=0.5$, IC 95%: margen $\pm 6\%$

Marco Teórico Subyacente

1. Capability Maturity Model Integration (CMMI)

CRA-Cyber adopta el esquema de 5 niveles de CMMI aplicado a ciberseguridad:

Nivel	Denominación	Característica
1	Initial	Procesos impredecibles, ad hoc
2	Managed	Procesos documentados, repetibles
3	Defined	Procesos estandarizados a nivel organizacional
4	Quantitatively Managed	Métricas cuantitativas, control estadístico
5	Optimizing	Mejora continua proactiva

2. NIST CSF 2.0 (Febrero 2024)

Marco de referencia para evaluación de controles, con 6 funciones (no 5 como versión anterior):

- Govern (GV): Políticas, riesgos, gobernanza
- Identify (ID): Contexto, inventario, evaluación
- Protect (PR): Controles técnicos, acceso, cifrado
- Detect (DE): Monitoreo, detección de anomalías
- Respond (RS): Investigación, contención
- Recover (RC): Restauración, business continuity

3. Activity-Based Costing (ABC) para CAsPeA

Metodología que asigna costes a actividades (no a centros de coste), permitiendo cuantificación precisa de costes de personal en seguridad.

Fórmula base:

Coste Actividad = Horas Dedicadas × Tasa Horaria Promedio
Coste Total = Σ Costes Actividades

4. Marco de Evaluación de Vulnerabilidades

Integración de múltiples sistemas de scoring:

- CVSS 3.1: Severidad teórica (0-10)
- EPSS: Probabilidad de explotación (0-100%)
- CISA KEV: Conocimiento de explotabilidad real
- Criticidad de activos: Contexto empresarial

PROCEDIMIENTO DE ADMINISTRACIÓN {#administración}

Fase 1: Preparación (Semanas 1-2)

1.1 Reclutamiento de Participantes

Estrategia de muestreo: Cuota deliberada estratificada (non-random)

- Sector: Distribuir proporcionalmente a población de operadores esenciales (NIS2)
- Tamaño: Incluir PYMES (50-249), empresas medianas (250-999), grandes (1000+)
- Geografía: Meta de cobertura territorial en España (mín. 5 CCAA)

Canales de reclutamiento:

- INCIBE (Instituto Nacional de Ciberseguridad) — contacto directo con miembros
- Cámaras de Comercio españolas
- Asociaciones sectoriales (bancos, sanitarios, energía)
- LinkedIn targeting (CISO, Security Director, IT Audit)
- Listados de auditores internos / consultorías Tier 1

1.2 Comunicación Inicial

Email de invitación (Plantilla):

Asunto: Participación en Estudio de Madurez de Ciberseguridad España [CONFIDENCIAL]

Estimado [Nombre],

Le invitamos a participar en un estudio de investigación sobre evaluación de madurez de ciberseguridad en España, auspiciado por [Institución].

Su participación:

- Duración: ~45-60 minutos (encuesta online)
- Confidencialidad: Datos anonimizados 100%, sin identificación individual
- Valor: Informe benchmarking sectorial (acceso prioritario a resultados)

Encuesta: [URL SEGURO]

Plazo: [Fecha límite, típicamente 3-4 semanas]

Agradecemos su colaboración en fortalecer la ciberseguridad nacional.

Atentamente,
[Investigador]

1.3 Configuración de Plataforma de Encuesta

Opciones recomendadas:

- **Google Forms:** Gratuito, simple, integración con Sheets
- **Qualtrics:** Profesional, análisis avanzado, seguridad certificada
- **SurveyMonkey:** Balance costo-funcionalidad
- **Jotform:** GDPR compliant, seguridad moderada

Configuración técnica obligatoria:

- [] HTTPS obligatorio (cifrado en tránsito)
- [] Autenticación opcional (permitir anónimo)
- [] Preguntas obligatorias vs opcionales (definir según importancia)
- [] Validación de tipos de datos (números para campos numéricos)
- [] Guardado automático (permitir pausa y reanudar)
- [] Tiempo límite de sesión (30 minutos inactividad = logout)

Fase 2: Lanzamiento (Semana 3)

2.1 Distribución de Encuesta

- Onda 1: 40% de la muestra objetivo
- Onda 2 (Semana 4): 40% restante (para captura de stragglers)
- Onda 3 (Semana 5-6): Invitaciones personalizadas a respondentes clave no completados

2.2 Apoyo a Respondientes

- FAQ preelaboradas: Responder dudas sobre terminología técnica
- Hotline de soporte: Email/teléfono para asistencia
- Recordatorios: Automáticos en días 7, 14, 21

Fase 3: Cierre y Validación (Semana 6-7)

- Fecha límite de respuesta
- Descarga de datos crudos
- Validación inicial (búsqueda de outliers, inconsistencias)

ANÁLISIS DESCRIPTIVO {#análisis}

3.1 Estadística Descriptiva Básica

Para cada pregunta numérica (Ej: MTTD en minutos):

Medidas de tendencia central:

Media = $\Sigma \text{Valores} / n$
Mediana = Valor central ($n/2$ -ésimo)
Moda = Valor más frecuente

Medidas de dispersión:

Desv. Estándar = $\sqrt{[\Sigma(x - \text{media})^2] / n-1}$
Coef. Variación = Desv. Estándar / Media (permite comparación entre escalas)
Rango = Máx - Mín
IQR = $Q3 - Q1$ (rango intercuartil, robusto a outliers)

Ejemplo — MTTD (Mean Time To Detect):

Si respondentes reportan MTTD:

- 30, 45, 60, 60, 90, 120, 180 minutos

Entonces:

- Media = $685/7 = 97.9$ minutos
- Mediana = 60 minutos (robusto, menos afectado por el 180)
- Moda = 60 minutos
- Desv. Est. = 52 minutos
- Coef. Var. = $52/98 = 0.53$ (53% variabilidad)

3.2 Análisis Categórico

Para preguntas de opción múltiple (Ej: sector, madurez):

Frecuencia Absoluta = Número de respondentes por categoría

Frecuencia Relativa = Frecuencia Absoluta / n * 100%

Ejemplo — Distribución por sector:

Sector	Frecuencia	%	Acumulado %
Financiero	32	21.3%	21.3%
Sanitario	28	18.7%	40.0%
Energía	25	16.7%	56.7%
AAPP	22	14.7%	71.4%
TIC	20	13.3%	84.7%
Otro	23	15.3%	100.0%
Total	150	100%	

3.3 Análisis de Brechas

Brecha = Objetivo - Estado Actual

KPI	Estado Actual	Objetivo	Brecha	Brecha %
MTTD	98 min	30 min	68 min	227%
Phishing report rate	12%	25%	-13 pp	-108%
Cobertura NIST Identify	51%	85%	34 pp	67%

Interpretación:

- Brecha positiva: Necesidad de mejorar (área subperformante)
- Brecha negativa: Superando objetivo (área de fortaleza)

3.4 Análisis Correlacional (Si aplica)

¿Existe relación entre tamaño de organización y madurez NIST?

Correlación de Spearman ρ = mide asociación monótona
(Preferible a Pearson para datos ordinales como Tier 1-5)

Interpretación:

- $\rho > 0.7$ = Correlación fuerte
- $\rho 0.3-0.7$ = Correlación moderada
- $\rho < 0.3$ = Correlación débil

CÁLCULOS CASPeA {#cálculos-caspea}

4.1 Fórmula Base CASPeA

$$\text{CASPeA Anual} = \sum (\text{FTE}_i \times \text{Tasa Horaria}_i \times \text{Horas Anuales}_i)$$

Donde:

- **FTE_i** = Full-Time Equivalents en rol i (puede ser <1 para personal compartido)
- **Tasa Horaria_i** = Salario anual / 1.800 horas/año (aprox.)
- **Horas anuales_i** = Horas dedicadas a actividades de ciberseguridad por FTE

Ejemplo de cálculo:

Organización: Banco medianas (500 empleados)

Rol	FTE	Salario Anual	Tasa Horaria	Horas/Año Seguridad	Coste
CISO	1.0	€75.000	€41,7	1.800	€75.000
Arquitecto Seg	2.0	€60.000	€33,3	1.800	€120.000
Analista SIEM	3.0	€48.000	€26,7	1.800	€144.000
Admin IAM	1.5	€45.000	€25,0	1.800	€67.500
Personal IT (10% tiempo seg)	8.0	€40.000	€22,2	180	€32.000
TOTAL	15.5 FTE				€438.500

Coste por empleado protegido = €438.500 / 500 = €877 / empleado / año

4.2 Desglose de CASPeA por Función NIST CSF

Asignar costes a funciones NIST basándose en dedicación:

Función NIST	Actividades	% del Tiempo	Coste Asignado
Govern	Gobernanza, políticas, cumplimiento	15%	€65.800
Identify	Inventarios, evaluación riesgos	20%	€87.700
Protect	Controles, acceso, cifrado	25%	€109.600
Detect	SIEM, monitoreo, análisis	20%	€87.700
Respond	Incidentes, investigación, contención	15%	€65.800
Recover	Continuidad, disaster recovery	5%	€21.900
TOTAL		100%	€438.500

Utilidad: Permite hacer pregunta "¿Cuánto cuesta alcanzar Tier 3 en Respond?" → Respuesta cuantificada en €.

4.3 Benchmarking de Costes por Sector

Construcción de tabla de referencia (requiere datos de múltiples organizaciones):

Sector	n	Coste Mediano (€)	Coste/Empleado	Rango IQR
Financiero	32	€1.220.000	€2.440	€890K-€1.8M
Sanitario	28	€680.000	€1.360	€420K-€1.1M
Energía	25	€920.000	€1.840	€620K-€1.4M
AAPP	22	€450.000	€900	€280K-€720K
TIC	20	€780.000	€1.560	€540K-€1.2M

Uso práctico:

- "Somos banco de 500 empleados; gastamos €600K en seguridad. ¿Es insuficiente?"
- Respuesta: "Mediana sector: €1.22M (€2.440/empleado). Ustedes: €1.200/empleado = 49% del mediano. Recomendación: aumentar a €2.2M para alcanzar percentil 50."

4.4 CAsPeA Dinámico (Post-Incidente)

Cuando ocurre incidente de seguridad, costes se disparan temporalmente:

Coste adicional estimado:

Fase	Multiplicador	Duración	Coste Incremental
Respuesta inmediata	2.5x	1-3 días	2.5x × (Coste Diario)
Investigación	2.0x	7-30 días	2.0x × (Coste Diario)
Remediación	1.5x	30-90 días	1.5x × (Coste Diario)
Post-mortem + mejoras	1.2x	90-180 días	1.2x × (Coste Diario)

Ejemplo: Banco con coste diario €1.200 sufre breach:

- Coste normal mes: €36.000

- Coste mes incidente (estimado): €36.000 × 1.3 (promedio ponderado) = €46.800

MÉTRICAS DE MADUREZ {#métricas}

5.1 Índice de Madurez General (IMG)

Agregación de todos los indicadores en una sola puntuación 0-100:

$$IMG = (\sum \text{Puntuación_Función} / 6) \times 100$$

$$\text{Donde Puntuación_Función} = (\% \text{ Controles Implementados} + \text{Tier Estimado} \times 20) / 2$$

Ejemplo:

Función	% Controles	Tier	Puntuación
Govern	62%	2.5	(62+50)/2 = 56
Identify	58%	2.3	(58+46)/2 = 52
Protect	65%	2.8	(65+56)/2 = 60,5
Detect	48%	1.9	(48+38)/2 = 43
Respond	42%	1.7	(42+34)/2 = 38
Recover	35%	1.5	(35+30)/2 = 32,5

$$IMG = (56+52+60,5+43+38+32,5) / 6 = 47 \text{ (Nivel 2 bajo - Emerging)}$$

5.2 Interpretation de IMG

IMG Range	Nivel	Interpretación	Acción Recomendada
0-20	1	Ausencia de controles formalizados	Evaluación completa requerida
21-40	1-2	Procesos ad hoc, inicio de formalización	Plan de mejora inmediato (12 meses)
41-60	2-3	Procesos documentados, falta integración	Consolidación y estandarización (18-24 meses)
61-80	3-4	Procesos integrados, falta optimización	Automatización y mejora continua (12-18 meses)
81-100	4-5	Sistema maduro, enfoque optimizado	Mantenimiento, innovación continua

BENCHMARKING {#benchmarking}

6.1 Comparativa Intra-Sectorial

Objetivo: Identificar si organización está por encima/debajo de par sectorial

Construcción de gráfico de caja (box plot):

Percentil 25 (Q1) ————
 Mediana (Q2) ————●
 Percentil 75 (Q3) ————

Mi organización (punto rojo) comparada con:
 - IQR (rango intercuartil) = 50% central de datos
 - Outliers (asteriscos) = organizaciones excepcionales

6.2 Análisis de Pares

Agrupar organizaciones por sector + tamaño:

"Organizations most similar to mine"

Crear perfil de control basado en:

1. Sector (match exacto)
2. Tamaño ($\pm 50\%$)
3. Criticidad (nivel similar)

Luego identificar "pares" y comparar KPIs

ANÁLISIS DE ROI {#roi}

7.1 Fórmula de ROI Cuantificado

$$\text{ROI (\%)} = [\text{Beneficio Neto} / \text{Inversión}] \times 100$$

Donde:

Beneficio Neto = Pérdida Evitada - Costes de Seguridad

Pérdida Evitada = Incidentes Prevenidos $\times$ Coste Promedio Incidente

Ejemplo:

Organización: Empresa sanitaria (2.000 empleados)

Datos:

- Inversión anual en seguridad: €450.000
- Incidentes históricos sin medidas: 5.2 incidentes/año
- Coste promedio incidente sin mitigación: €180.000
- Pérdida histórica: $5.2 \times €180K = €936.000/\text{año}$

Con programa de seguridad implementado:

- Incidentes reducidos a: 1.8 incidentes/año (65% reducción)
- Pérdida residual: $1.8 \times €180K = €324.000/\text{año}$
- Pérdida evitada: $€936K - €324K = €612.000$

$$\text{ROI} = (\text{€}612.000 - \text{€}450.000) / \text{€}450.000 \times 100 = 36\% \text{ anual}$$

7.2 Componentes de Beneficio

Fuente de Beneficio	Cálculo	Estimado
Incidentes prevenidos	(Tasa sin seguridad - Tasa con seguridad) $\times$ Coste promedio	€612.000
Conformidad legal	Multas evitadas (GDPR, NIS2)	€50.000
Reputación	Valor evitado de daño a marca (conservador 1-5% revenue)	€120.000
Continuidad operativa	Horas evitadas de downtime $\times$ Coste operativo	€40.000
Productividad (menos incidentes)	FTE salvadas de respuesta	€30.000
TOTAL BENEFICIO ANUAL		€852.000

$$\text{ROI más realista} = (\text{€}852.000 - \text{€}450.000) / \text{€}450.000 = 89\% \text{ anual}$$

7.3 Payback Period

Tiempo para recuperar inversión inicial:

$\text{Payback Period} = \text{Inversión Inicial} / \text{Beneficio Neto Anual}$

Ejemplo: $€450.000 / €402.000 = 1.12 \text{ años} \approx 13.4 \text{ meses}$

TRATAMIENTO DE DATOS FALTANTES {#tratamiento}

8.1 Mecanismos de Pérdida de Datos

- Omisión intencional (respondiente saltó pregunta)
- Omisión involuntaria (respondiente no sabe respuesta)
- Abandono de encuesta (se fue antes de terminar)

8.2 Estrategias de Imputación

Para preguntas críticas (ej: sector, tamaño):

Opción A — Exclusión:

- Si >30% datos faltantes en pregunta: descartar pregunta
- Si >30% datos faltantes en respondiente: descartar respondiente

Opción B — Imputación Media/Mediana:

- Reemplazar valor faltante con media/mediana del grupo similar
- Uso: Para KPIs numéricos (MTTD, coste)

Opción C — Imputación Forward:

- Si respondiente abandona a mitad, usar respuestas parciales + marcar como "incompleta"

8.3 Documentación

Reportar en anexo metodológico:

- % de datos faltantes por pregunta
- Método de imputación usado
- Análisis de sensibilidad (resultados con/sin datos imputados)

VALIDACIÓN Y ASEGURAMIENTO DE CALIDAD {#validación}

9.1 Validación de Entrada de Datos

Chequeos automatizados:

```
IF (Tamaño = "10-49 empleados" AND Coste Anual = "€5.000.000")  
  THEN Flag = "Outlier sospechoso – revisar"
```

Reglas de validación lógica:

Regla	Lógica	Acción si Incumplida
Coherencia tamaño-costes	Coste/empleado sensato (€500-€3.000)	Revisar con respondiente
Coherencia madurez-costes	Tier 4 debería tener >€1.5M costes	Flag para revisión
Compleitud datos críticos	Sector + Tamaño + KPIs principales	Solicitar completitud
Rangos sensatos	MTTD: 5-1440 minutos (5 min - 24h)	Outliers normalizados o excluidos

9.2 Test de Coherencia Interna

Validar respuestas inconsistentes:

Ejemplo:

- P1: "Realizamos pentesting cada 6 meses"
- P2: "Nuestro programa de pentesting es Nivel 1 (ad hoc)"

— Inconsistencia. Contactar respondiente para aclarar.

9.3 Pruebas Piloto

Antes de lanzamiento a escala completa:

- Prueba con 10-15 respondientes (mix sectorial)
- Tiempo: Medir duración real (meta: 50-65 minutos)
- Claridad: ¿Preguntas mal entendidas?
- Validez: ¿Respuestas sensatas, rango esperado?
- Iteración: Ajustar preguntas ambiguas, eliminar redundancias

APÉNDICE: PLANTILLA DE TABLA DE CÁLCULOS

HOJA DE TRABAJO: CÁLCULO CASPeA PARA MI ORGANIZACIÓN

Datos Básicos

Sector: _____

Tamaño (empleados): _____

Tamaño muestra (empleados con acceso IT): _____

Año fiscal: _____

Personal Dedicado a Seguridad

Rol	FTE	Salario Anual (€)	Horas/Año Seg.	Tasa Horaria (€)	Coste (€)
CISO					
Arquitecto					
(Continuar...)					
TOTAL				**€_____**	

Asignación a Funciones NIST

(Usar totales anteriores)

Función	% Dedicación	Coste Asignado (€)
Govern	__%	
Identify	__%	
(Continuar...)	__%	
TOTAL	100%	**€_____**

Cálculo CASPeA Normalizado

Coste/Empleado = Coste Total / Empleados con acceso IT = ****€_____****

Comparativa sector (mediana): ****€_____ / empleado****

Posición percentil: ****_____****

Recomendación: ****Aumentar / Mantener / Reducir****

Fin de Guía Metodológica CRA-Cyber v2.1